

C&S Wholesale Grocers, Inc. and Subsidiaries

Policy Title: User Logical & Physical Access Management
Status: Annual Review
Policy Owner: IS Security and Compliance
Original Issue Date: 07/12/2012

SOP# CSISSD003
Version: 2.0
Department: IT
Effective Date: 07/12/2012

Document History

Document Revision	Reviewer	Description of Changes	Date
1	Diptanil Paul	Annual Review	07/30/2022
2	Sarah Ward	Document History table added Table of Contents added	03/23/2023
3	Diptanil Paul	Annual Review	08/01/2023
4	Larry Risher	Changes to Strengthen Password Security Policy content updated	09/16/2025
5	Diptanil Paul	Annual Review	11/24/2025

C&S Wholesale Grocers, Inc. and Subsidiaries

Table of Contents

Document History 1

1. Purpose 3

2. Management Responsibility 3

3. Logical and Physical Access Management Policy 3

 3.1. Logical Access Requirements 3

 3.2. Identity Management Requirements 3

 3.3. Physical Access 4

4. Roles and Responsibilities 5

5. Definitions 5

6. Related Documents 6

C&S Wholesale Grocers, Inc. and Subsidiaries

1. Purpose

To ensure information services systems, applications, and datacenters are restricted to authorized personnel requiring access to execute their job responsibilities.

2. Management Responsibility

It is the manager's responsibility to ensure that his/her direct-report employees, interns, contractors, and/or third-party are aware of, and agree to abide by, the Company's security and professional conduct rules regarding Logical and Physical access. Managers are also responsible for promptly notifying the HR department when an employee's employment terminates, or a third party's access is no longer authorized so that any logical or physical access can be promptly removed after termination.

3. Logical and Physical Access Management Policy

3.1. Logical Access Requirements

3.1.1. Identity Management and Network Access

Access to the C&S network is authorized through the Security Access Request (SAR) process. The role of Information Services is to initialize or terminate identity and access to the Information Services Network based on the on-boarding and off-boarding processes driven by the SAR and Human Resources.

3.1.2. Application Access

Application access is authorized by Business Liaisons or their designees. Once an identity and network access has been granted, the Business Liaison or designee authorizes access to specific applications. The primary point of control for application access is the Business Liaison or designee for a given Business unit. The SAR process should be leveraged to initialize or terminate access to C&S applications.

3.1.3. Privileged Access

Privileged access applies to all administrative access including, but not limited to operating systems, databases, and applications. This kind of access is typically restricted to IS personnel only and restricted to those users with job-appropriate responsibilities such as system administrators, network engineers, or security engineers. All privileged access must be granted through the Security Access Request process.

3.1.4. Privileged Account Management

The requirements for privileged accounts are:

- Wherever possible, the same account that is used for day-to-day non-privileged access should not be used for privileged access. Separate privileged accounts should be used to allow individuals to gain access not provisioned to normal users.
- Wherever possible, Multi-Factor authentication should be leveraged for all privileged access to cloud based and on-premise systems and applications.

3.2. Identity Management Requirements

3.2.1. General User ID's and Password Requirements

The requirements for User ID's and Passwords are:

- An initial strong and unique password should be created on account setup and communicated to the user via secure means.
- User ID's will be owned by a single user and will be used only by this user.
- Initial passwords must be unique for every user ID and must be changed on initial login and whenever changed or reset by the helpdesk.
- Passwords must not be shared with anyone or written down.
- Passwords must not be displayed on the user's screen or within the user's work area.

3.2.2. General User ID's and Password Technical Requirements

The technical requirements for User ID's and Passwords are:

- Password Minimum Length: 14 characters
- Password Minimum Age: 3 days
- Password Maximum Age: 90 days
- Password History : 12
- Password Complexity Requirements, at least three of the following: 1 capital letter, 1 lowercase letter, 1 number, or 1 special character
- Lockout Threshold: 10
- Lockout Duration: 30 minutes
- Inactivity Timeout (i.e. session lock): 30 minutes

C&S Wholesale Grocers, Inc. and Subsidiaries

- Screen Saver Session Lock: 10 minutes

3.2.3. Service Account User ID's and Password Technical Requirements

The requirements for Service Account User ID's and Passwords are:

- Password Minimum Length: 14 characters
- Password Minimum Age: N/A
- Password Maximum Age: N/A
- Password History : 5
- Password Complexity Requirements, at least three of the following: 1 capital letter, 1 lowercase letter, 1 number, or 1 special character
- Lockout Threshold: 5
- Lockout Duration: Require IT intervention to unlock
- Inactivity Timeout (i.e. session lock): N/A
- Screen Saver Session Lock: N/A
- Service accounts must not be allowed for interactive login. (e.g. RDP, establishing user sessions, etc.)

3.2.4. Login Failure Lockout Requirements

- User accounts shall be locked after six (6) consecutive authentication failures.
- Users must contact the Help Desk Operations to have their account reset.

3.2.5. Password Support

Before a password is reset for a Workforce Member, their identity must be verified. The verification can be accomplished by, for example, calling the individual back on the phone number listed in Active Directory or Workday.

3.2.6. Access Review

- Key applications requiring routing access review will be identified by IS management
- System access and privileges for key applications controlled through directory services will be validated on a quarterly basis.
- System access and privileges controlled through Mainframe RACF will be validated at a minimum once annually.

3.2.7. User Accounts

- A reconciliation of directory services accounts shall be performed at least quarterly.
- Those accounts that have not been accessed in 32 days shall be disabled.
- Accounts not used in 64 days shall be deleted.

3.2.8. Terminations

Upon receipt of notification from HR for urgent terminations or suspensions, IS must disable accounts within two (2) hours.

3.2.9. Password Encryption

Passwords must be encrypted during transmission and storage on all system components where possible.

3.3. Physical Access

3.3.1. General Building Access

- Physical access to all corporate facilities is managed by the Security and Facilities departments.
- All facilities must be physically protected in proportion to the criticality or importance of their function.
- The process for granting card and/or key access to corporate facilities must include the approval of the hiring manager and a Human Resources representative, the exception being Data Center access
- Access cards and/or keys must not be shared or loaned to others.
- Access cards and/or keys that are no longer required must be returned to the person responsible for the facility. Cards must not be reallocated to another individual.
- Lost or stolen access cards and/or keys must be reported to the person responsible for the facility/equipment immediately upon discovery.

3.3.2. Data Center Access Authorization

- Access is restricted to Information Services and Maintenance associates as well as support vendors with job responsibilities requiring physical presence in the Data Center.

C&S Wholesale Grocers, Inc. and Subsidiaries

- Access will only be authorized through a written request from an Information Services Director, Sr. Director, or Vice President to the Sr. Director of IS Operations. All requests must provide appropriate justification for approval.

3.3.3. Data Center Access Review

- The Authorized Data Center Users List will be reviewed on a monthly basis to ensure the list is correct and current.
- The "Last Accessed" list will be reviewed quarterly.
- The sign-in log and lists of authorized users with access will be retained for a period of not less than one year.

3.3.4. Data Center Visitor Access

- Any non-employee to the Data Center is required to sign a logbook.
- Activities within the Data Center shall be restricted as much as possible to the area where the person's equipment and/or systems are stationed.

3.3.5. Data Center Guidelines

- Access to the Data Center is by key card. The Data Center door will remain securely locked at all times.
- All personnel are required to report any problems within the Data Center to the senior Operations person on duty.
- No food or drink is allowed in the Data Center.

4. Roles and Responsibilities

Role	Responsibility
Business Liaison	Business Liaisons are responsible for facilitating alignment between their respective business units and IS.
Hiring or Department Manager	Individual directly responsible for associates and non-employees requesting access.
Human Resources	Source of verification for all active associates and non-employees needing access to corporate networks and applications.
Telecommunications	Responsible for telephony set up and directory maintenance.

5. Definitions

Term	Definition
Users	Associates or non-employees that require access to IS controlled systems, applications, or data centers; they are responsible for compliance with all aspects of this policy and related documents.
Access control	The management of access to all Information Services networks, systems and applications. Access control includes the enforcement of specified authorization rules based on positive identification of users and the systems or data they are permitted to access, and providing access to authorized users while denying access to unauthorized users.
Active Directory (AD)	A directory service created by Microsoft which: • Centralizes authentication and authorization services for Windows-based computers. • Contains user information that is available for email and for the corporate phone directory. • Allows administrators to assign policies, deploy software, and apply critical updates to an organization. • Keeps information and settings in a central database.
On-boarding	The process by which a new associate or non-employee is provided with the appropriate work space, computer, telephone, and network/system access.

C&S Wholesale Grocers, Inc. and Subsidiaries

Term	Definition
Off-boarding	The process by which an associated or non-employee is terminated from business activities. This includes removing all access to business applications, email, remote access, and voice services.

6. Related Documents

Any related documents shall include the prefix CSISSD003.